

DOCUMENTACIÓN TÉCNICA PROFESIONAL

Políticas corporativas en FortiGate Firewall

WAF - Application Control - DNS Filter - Web Filter - DHCP - NAT - DoS Policy

Autor	Michael David Robles Fermín
Matrícula	2025-0845
Asignatura	Seguridad de Redes
Docente	Jonathan Rondón
Plataforma	GNS3, FortiGate VM, Kali Linux, Windows Server/IIS
Repositorio	https://github.com/iClexi/Fortigate-Corporate-Policies
Video demostrativo	https://youtu.be/9Mjof5YxtKg?si=TpSuH9TQf1OwJGXo

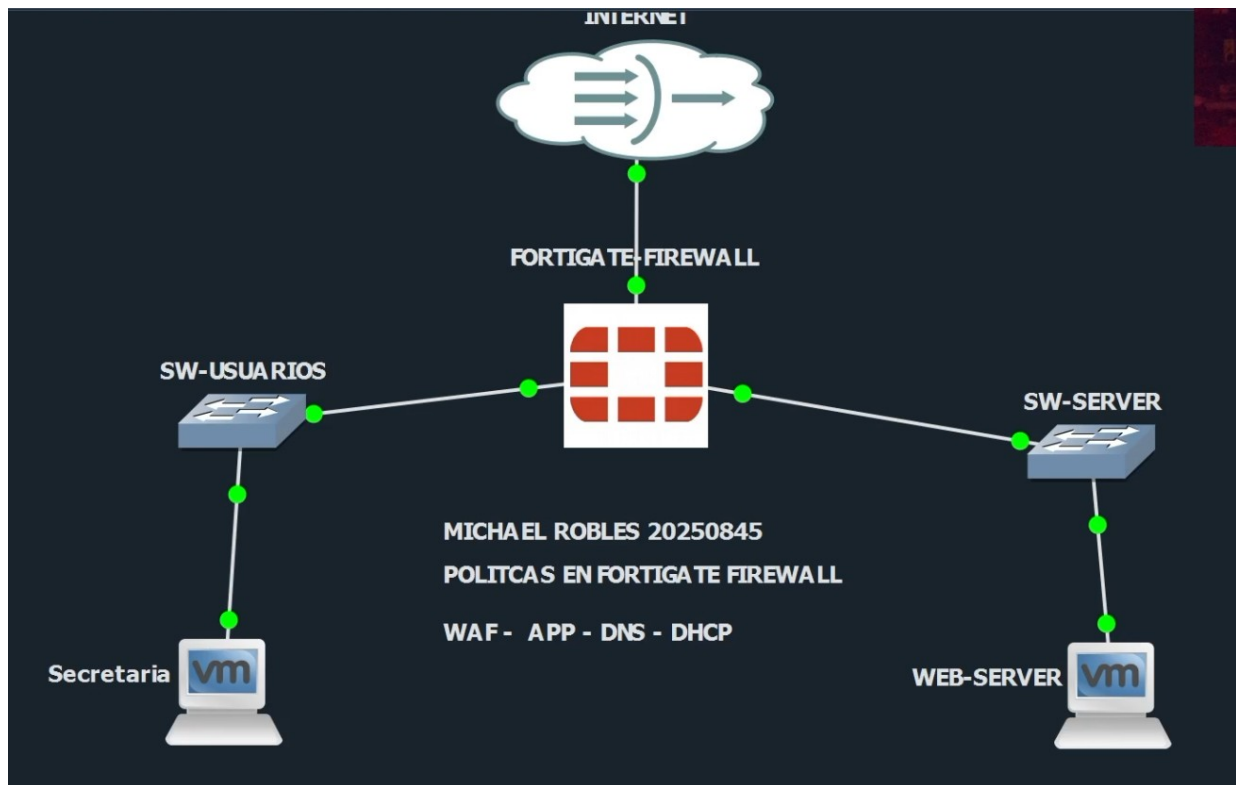


Figura 1. Topología general del laboratorio FortiGate Corporate Policies.

Índice

1. Introducción
2. Objetivos del laboratorio
3. Alcance y uso responsable
4. Resumen ejecutivo de la solución
5. Topología y segmentación de red
6. Direccionamiento IP
7. Configuración base del FortiGate
8. Políticas de firewall y control de acceso
9. Filtrado web, DNS Filter y bloqueo de WhatsApp
10. Detección y bloqueo de escáneres de red
11. Servidor web y validación de acceso HTTP
12. Web Application Firewall
13. Pruebas de validación
14. Observaciones técnicas
15. Conclusión
16. Anexos

1. Introducción

Este documento presenta la documentación técnica profesional del laboratorio FortiGate Corporate Policies. La práctica fue desarrollada en un entorno controlado de GNS3 utilizando un FortiGate VM como firewall perimetral y de segmentación, una estación Kali Linux como cliente de la red de usuarios, un Windows Server con IIS como servidor web y switches de capa 2 para la conexión de cada zona.

El laboratorio simula una red corporativa básica donde el FortiGate separa tres dominios de tráfico: WAN, LAN de usuarios y LAN de servidores. Sobre esta arquitectura se implementaron políticas de seguridad orientadas a permitir navegación controlada, segmentar servidores, bloquear dominios no autorizados, controlar aplicaciones, registrar eventos de escaneo y proteger un sitio web mediante WAF.

2. Objetivos del laboratorio

El objetivo principal es demostrar la aplicación de políticas corporativas en FortiGate Firewall usando una topología realista y verificable. La solución debe permitir conectividad legítima y bloquear tráfico no autorizado, manteniendo evidencias claras en la interfaz gráfica y en los logs del FortiGate.

- Configurar interfaces del FortiGate para WAN, LAN de usuarios y LAN de servidores.
- Implementar una red de usuarios /25 y una red de servidores /28.
- Configurar DHCP en la LAN de usuarios para entregar IP, gateway y DNS.
- Configurar ruta por defecto y NAT para permitir salida a Internet.
- Permitir acceso web desde usuarios hacia el servidor y bloquear el resto del tráfico hacia servidores.
- Bloquear redes sociales mediante Web Filter, filtros estáticos y redirección DNS.
- Bloquear llamadas de WhatsApp mediante Application Control.
- Bloquear itla.edu.do y subdominios mediante DNS Filter y portal de bloqueo.
- Detectar y bloquear escaneos de red con políticas IPv4 DoS.
- Aplicar WAF al servidor web y validar el bloqueo de ataques XSS.

3. Alcance y uso responsable

La práctica fue realizada exclusivamente con fines académicos en un ambiente aislado de laboratorio. Las pruebas de escaneo, bloqueo de dominios, Application Control y WAF se ejecutaron contra equipos propios del escenario. No se debe replicar este tipo de pruebas contra redes públicas, sitios reales o sistemas de terceros sin autorización explícita.

4. Resumen ejecutivo de la solución

La solución implementa un FortiGate como punto central de seguridad. El firewall recibe tráfico de usuarios por port2, tráfico de servidores por port3 y salida a Internet por port1. A partir de esa separación, las políticas permiten Internet con NAT, publican el servidor web interno de forma controlada, bloquean accesos no autorizados y registran eventos de seguridad.

Las evidencias muestran que google.com resuelve hacia direcciones reales mientras dominios como facebook.com, whatsapp.com e itla.edu.do son redirigidos hacia el portal interno 10.8.45.130. También se demuestra que un escaneo Nmap genera eventos de denegación y anomalías, y que un intento de XSS es bloqueado por el WAF antes de llegar al servidor IIS.

5. Topología y segmentación de red

La topología del laboratorio se divide en tres zonas conectadas directamente al FortiGate. La zona WAN simula el acceso a Internet. La LAN de usuarios representa los equipos finales que necesitan navegación y acceso limitado a recursos internos. La LAN de servidores contiene el servidor web protegido por políticas y WAF.

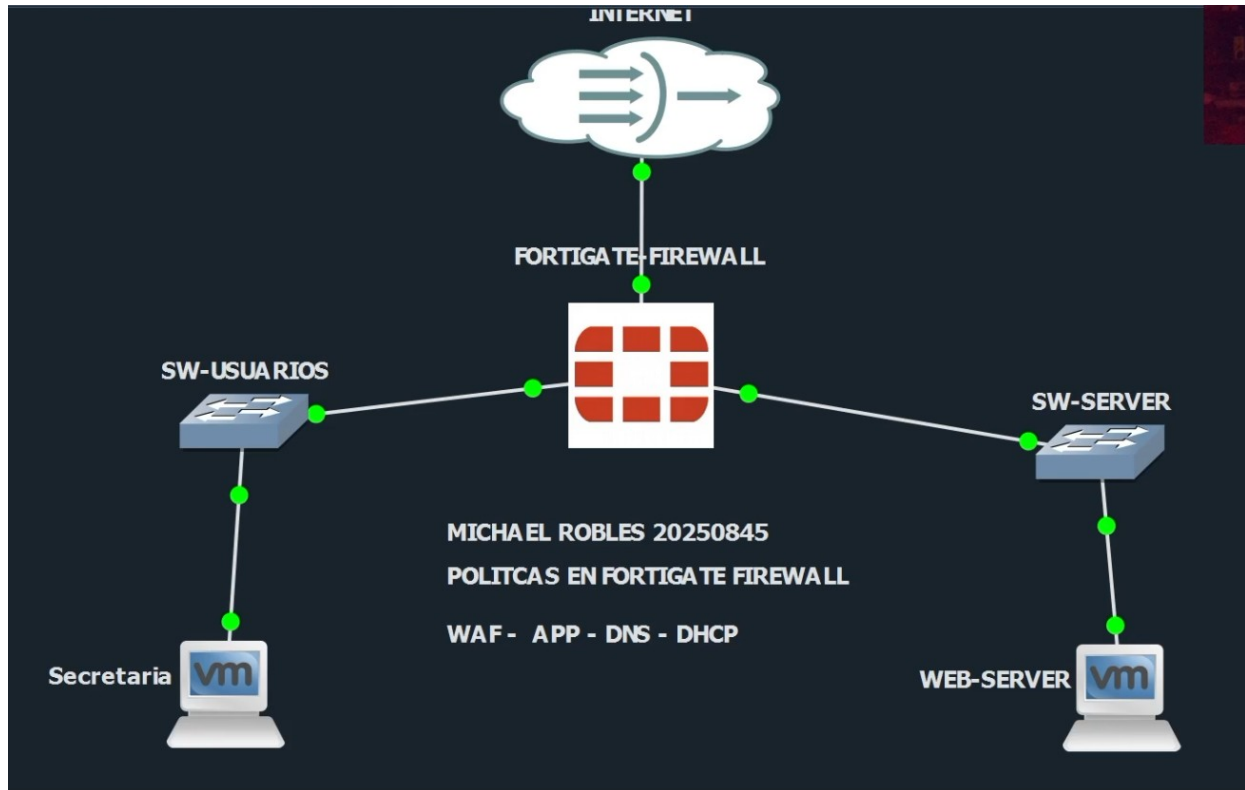


Figura 1. Topología general del laboratorio.

La evidencia presenta el diseño general en GNS3. El FortiGate queda al centro como equipo perimetral y de segmentación. En la parte superior se muestra la salida hacia Internet; a la izquierda se encuentra la red de usuarios conectada al switch SW-USUARIOS y a la estación Secretaria/Kali; a la derecha se muestra la red de servidores conectada al switch SW-SERVER y al equipo WEB-SERVER. También se observan los datos del estudiante, matrícula y el enfoque del laboratorio: políticas en FortiGate Firewall, WAF, Application Control, DNS y DHCP.

6. Direccionamiento IP

El direccionamiento se calculó a partir de la matrícula 2025-0845, utilizando el bloque 10.8.45.0 para usuarios y servidores. La LAN de usuarios se configuró como /25 y la LAN de servidores como /28. Esta separación permite aplicar reglas distintas para clientes y servidores.

Elemento	Interfaz	IP/Máscara	Descripción
WAN_INTERNET	port1	192.168.42.103/24	Salida hacia NAT1/Internet
LAN_USUARIOS	port2	10.8.45.1/25	Gateway de usuarios
LAN_SERVIDORES	port3	10.8.45.129/28	Gateway de servidores
Cliente Kali	eth0	10.8.45.10/25	Equipo de pruebas en usuarios
WEB_SERVER	NIC	10.8.45.130/28	Servidor IIS protegido

7. Configuración base del FortiGate

7.1 Ruta estática por defecto

La ruta por defecto 0.0.0.0/0 es necesaria para que el tráfico de usuarios y servidores pueda salir hacia redes externas. En la evidencia, el next-hop es 192.168.42.1 y la interfaz de salida es WAN_INTERNET, asociada a port1.

Destination	Gateway IP	Interface	Status	Comments
0.0.0.0/0	192.168.42.1	WAN_INTERNET (port1)	Enabled	

Figura 2. Ruta estática por defecto hacia Internet.

La captura muestra la tabla de rutas estáticas del FortiGate. Existe una ruta 0.0.0.0/0 con gateway 192.168.42.1 y salida por la interfaz WAN_INTERNET, correspondiente a port1. Esta ruta permite que el firewall envíe hacia Internet todo tráfico cuyo destino no pertenezca a las redes internas.

7.2 Interfaces físicas

Las interfaces muestran la separación física de funciones. port1 funciona como WAN, port2 como LAN de usuarios y port3 como LAN de servidores. Esta división es clave para crear políticas por zonas y mantener un flujo claro entre origen y destino.

Name	Type	Members	IP/Netmask	Administrative Access	DHCP Clients	DHCP Ranges	Ref.
802.3ad Aggregate	802.3ad Aggregate		Dedicated to FortiSwitch	PING Security Fabric Connection			1
fortilink	Physical Interface						
LAN_SERVIDORES (port3)	Physical Interface		10.8.45.129/255.255.255.240	PING			7
LAN_USUARIOS (port2)	Physical Interface		10.8.45.1/255.255.255.128	PING HTTPS SSH		10.8.45.20-10.8.45.120	7
WAN_INTERNET (port1)	Physical Interface		192.168.42.103/255.255.255.0	PING			4
NAT interface (na/root)	Tunnel Interface		0.0.0.0/0.0.0.0				0

Figura 3. Interfaces físicas del FortiGate.

La lista de interfaces evidencia tres zonas principales: WAN_INTERNET en port1 con dirección 192.168.42.103/24, LAN_USUARIOS en port2 con dirección 10.8.45.1/25 y LAN_SERVIDORES en port3 con dirección 10.8.45.129/28. También se observa el rango DHCP asociado a port2, de 10.8.45.20 a 10.8.45.120.

7.3 Configuración de LAN de usuarios y DHCP

La interfaz port2 se configuró con dirección 10.8.45.1/25 y acceso administrativo habilitado para las necesidades del laboratorio. Sobre esta misma interfaz se activó el servidor DHCP para entregar direcciones dentro del rango definido a los clientes de usuarios.

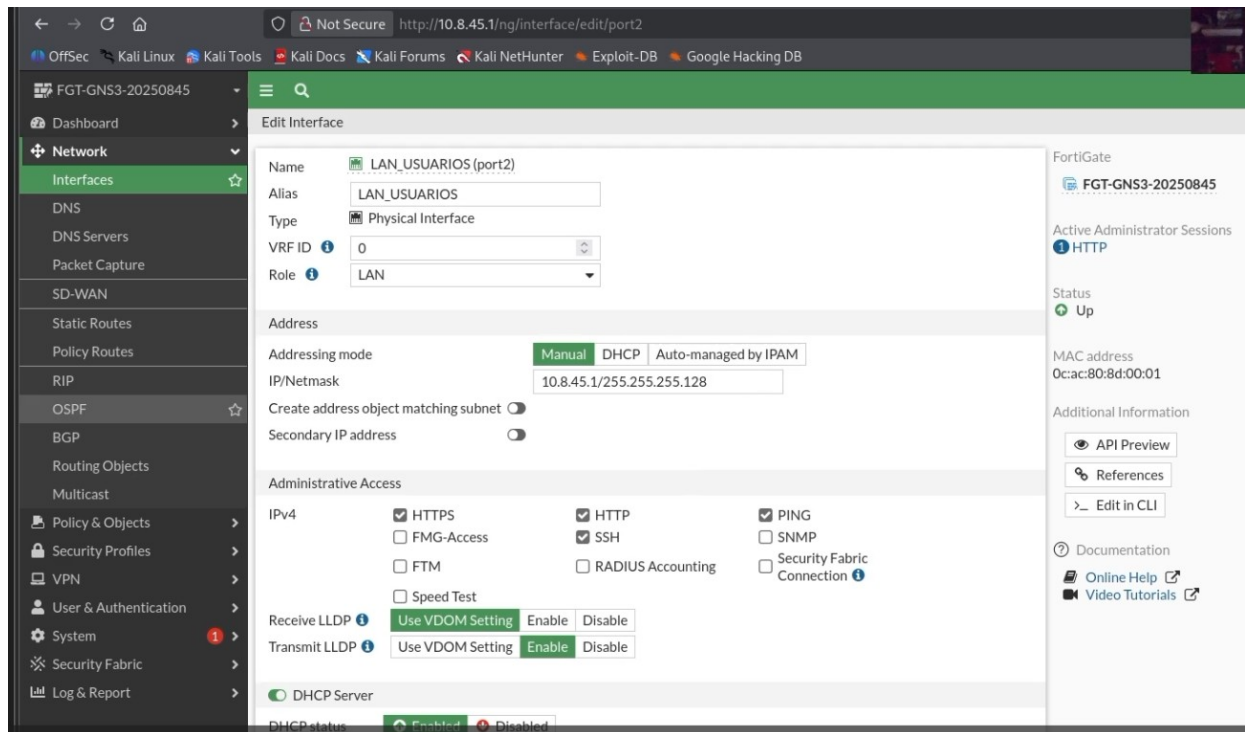


Figura 4. Configuración IP y acceso administrativo de port2.

La evidencia muestra la edición de la interfaz LAN_USUARIOS, asociada a port2. La interfaz está en modo manual con IP 10.8.45.1 y máscara 255.255.255.128, que corresponde a la red /25 de usuarios. También aparecen habilitados los accesos administrativos HTTP, HTTPS, SSH y PING, lo cual permite administrar el FortiGate desde la red de laboratorio.

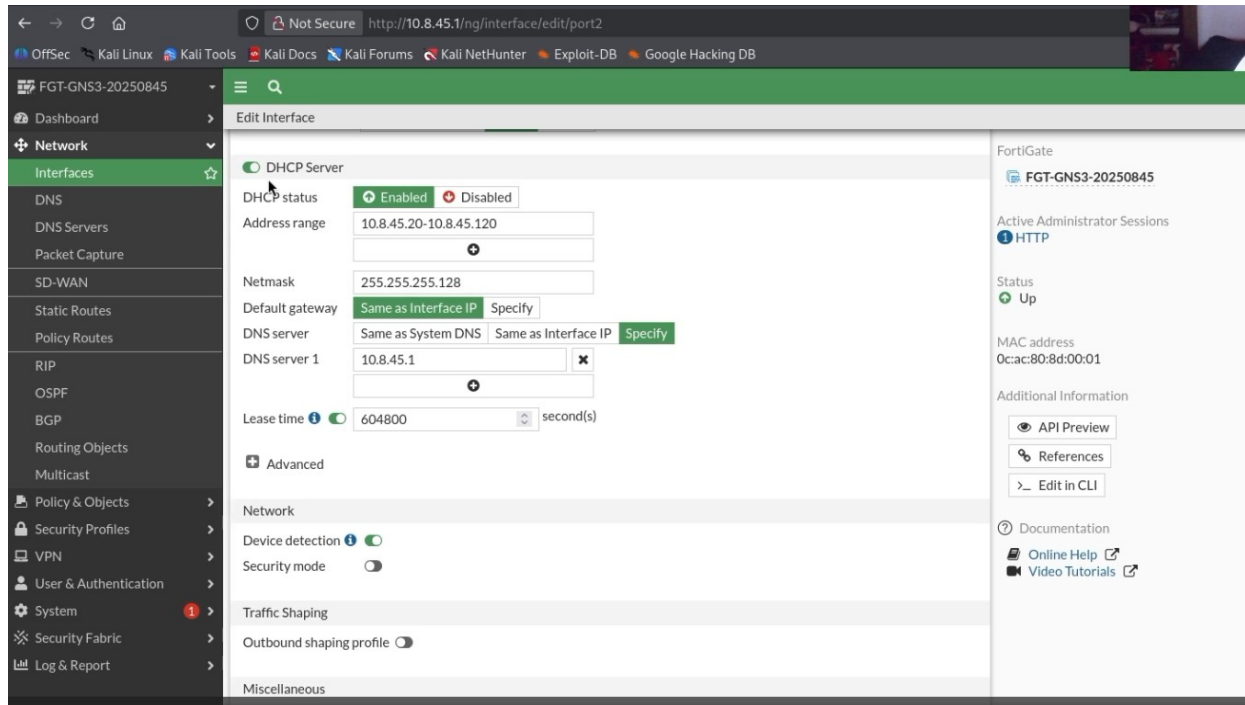


Figura 5. Servidor DHCP de la LAN de usuarios.

La captura muestra el DHCP Server activado en port2. El rango asignado es 10.8.45.20-10.8.45.120, con máscara 255.255.255.128, gateway igual a la IP de la interfaz y DNS configurado como 10.8.45.1. Con esto, los clientes de la LAN de usuarios reciben parámetros de red desde el FortiGate.

8. Políticas de firewall y control de acceso

Las políticas de firewall son el núcleo del control de acceso. El orden de las reglas es importante: primero se permiten flujos específicos y después se deniega lo que no debe pasar. En este laboratorio se permite Internet con NAT, se permite tráfico web hacia el servidor y se bloquea el resto del tráfico desde usuarios hacia la red de servidores.

Policy & Objects

Firewall Policy

IPv4 DoS Policy

Addresses

Internet Service Database

Services

Schedules

Virtual IPs

IP Pools

Protocol Options

Traffic Shaping

Security Profiles

VPN

User & Authentication

System

Security Fabric

Log & Report

LAN_SERVIDORES (port3) → WAN_INTERNET (port1)

SERVICES_TO_INTERNET

LAN_SERVIDORES_NET

all

always

ALL

ACCEPT

Enabled

no-inspection

All

413.971

LAN_USUARIOS (port2) → LAN_SERVIDORES (port3)

ALLOW_USERS_HTTP_TO_WEB

LAN_USUARIOS_NET

WEB_SERVER

always

HTTP
HTTPS

ACCEPT

Disabled

WAF_WEB_SERVER_PROTECTION
certificate-inspection

All

824.19

DENY_USERS_TO_SERVERS

LAN_USUARIOS_NET

LAN_SERVIDORES_NET

always

ALL

DENY

All

323.05

LAN_USUARIOS (port2) → WAN_INTERNET (port1)

USERS_TO_INTERNET

LAN_USUARIOS_NET

all

always

ALL

ACCEPT

Enabled

BLOCK_SOCIAL_NETWORKS
BLOCK_WHATSAPP_CALLS
certificate-inspection

All

27.741

Implicit

Implicit Deny

all

all

always

ALL

DENY

Disabled

5.43

Figura 6. Vista general de políticas de firewall.

La vista general organiza las políticas por flujo de interfaces. Se observan reglas desde LAN_SERVIDORES hacia WAN_INTERNET, desde LAN_USUARIOS hacia

LAN_SERVIDORES y desde LAN_USUARIOS hacia WAN_INTERNET. La regla de acceso a servidores usa WAF; la regla de Internet usa Web Filter, Application Control y certificado de inspección; y la regla de denegación registra las violaciones hacia servidores.

8.1 Salida de servidores hacia Internet

La política SERVERS_TO_INTERNET permite que la red de servidores salga a Internet. Aunque no es la política principal para los usuarios, es útil para mantenimiento del servidor, pruebas de conectividad o actualizaciones del sistema. El NAT se realiza con la dirección de salida de la interfaz WAN.

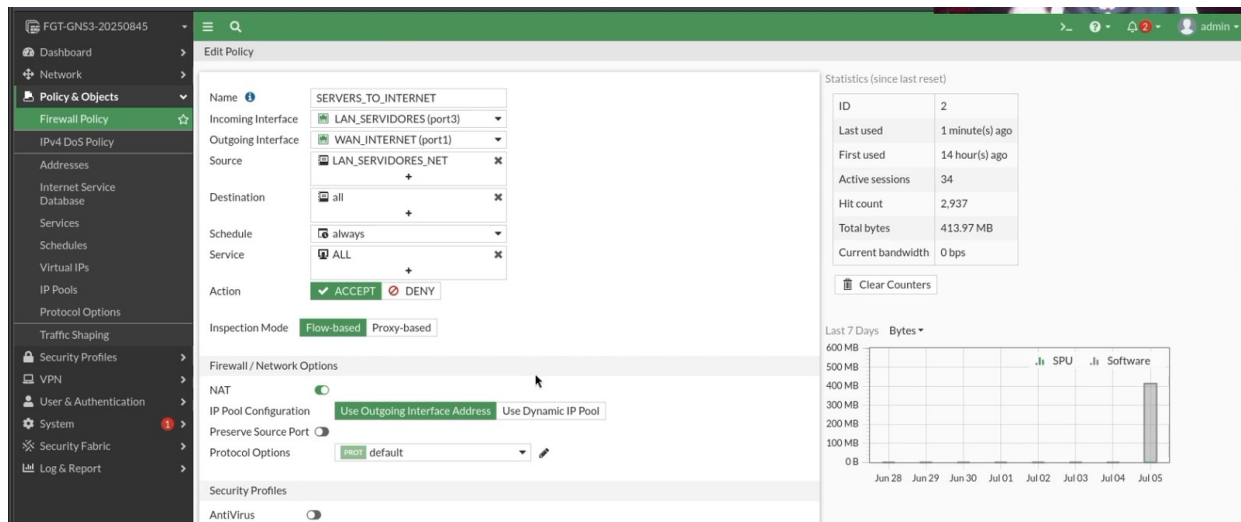


Figura 7. Política SERVERS_TO_INTERNET.

La política SERVERS_TO_INTERNET permite que la red de servidores salga hacia Internet desde port3 hacia port1. El origen es LAN_SERVIDORES_NET, el destino es all, el servicio es ALL y la acción es ACCEPT. Esta regla es útil para que el servidor pueda resolver, actualizarse o comunicarse externamente si el laboratorio lo requiere.

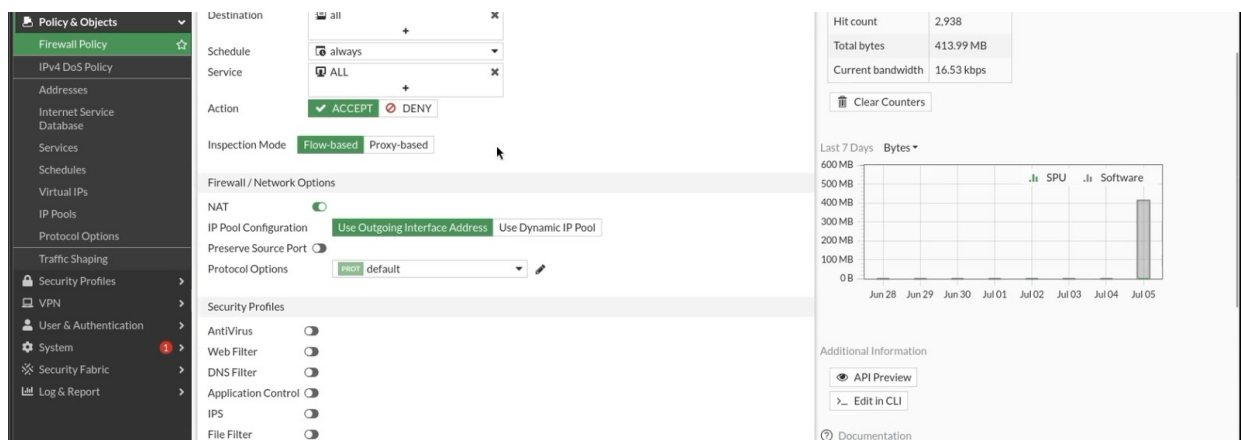


Figura 8. NAT en SERVERS_TO_INTERNET.

La segunda parte de la política muestra NAT habilitado con la opción Use Outgoing Interface Address. Esto significa que el tráfico de los servidores será traducido usando la dirección de la interfaz de salida WAN_INTERNET. También se observa modo flow-based y protocolo default.

8.2 Acceso web de usuarios hacia el servidor

La política ALLOW_USERS_HTTP_TO_WEB permite el tráfico desde LAN_USUARIOS hacia el objeto WEB_SERVER. La política usa modo proxy-based para poder aplicar WAF. NAT está deshabilitado porque el tráfico no sale a Internet, sino que viaja entre dos redes internas del laboratorio. En la evidencia se observa HTTP y HTTPS; para cumplimiento estricto de un escenario que exija únicamente HTTP, se puede retirar HTTPS y mantener solo HTTP.

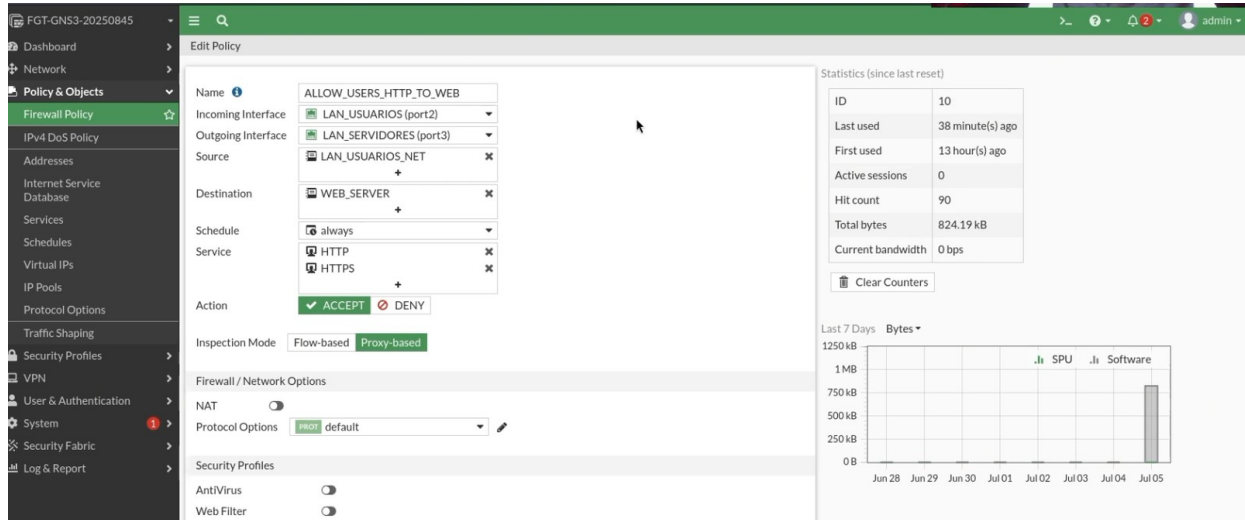


Figura 9. Política ALLOW_USERS_HTTP_TO_WEB.

La captura evidencia la regla que permite el acceso web desde LAN_USUARIOS hacia WEB_SERVER por port3. El origen es LAN_USUARIOS_NET y el destino es el objeto WEB_SERVER. La política está en proxy-based y tiene NAT deshabilitado porque el tráfico se queda dentro del entorno interno. En la evidencia se observan los servicios HTTP y HTTPS; el servicio principal requerido para la demostración es HTTP, y HTTPS puede mantenerse para pruebas de portal o retirarse si se exige cumplimiento estricto de solo HTTP.

8.3 Denegación del resto del tráfico hacia servidores

La política DENY_USERS_TO_SERVERS funciona como cierre de seguridad. Si un usuario intenta acceder a puertos que no fueron permitidos por la regla anterior, el FortiGate lo bloquea y genera un log. Esta regla fue validada con Nmap y con la vista de Forward Traffic.

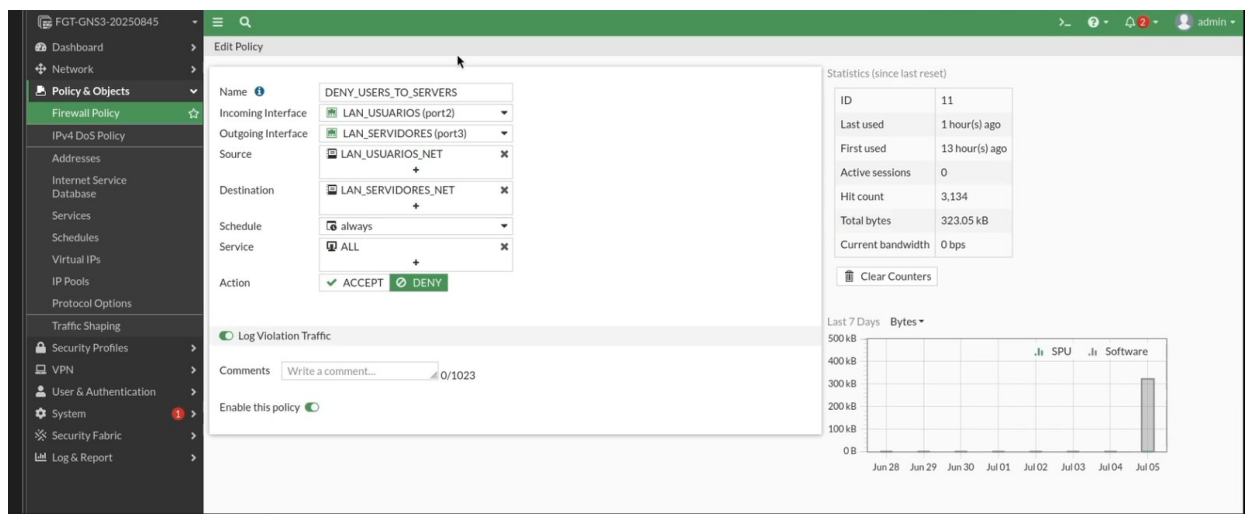


Figura 10. Política DENY_USERS_TO_SERVERS.

La regla DENY_USERS_TO_SERVERS bloquea todo tráfico desde LAN_USUARIOS hacia LAN_SERVIDORES_NET que no haya sido permitido previamente por una política superior. La acción DENY está activa, el servicio es ALL y Log Violation Traffic está habilitado. Esta regla materializa el principio de mínimo privilegio entre usuarios y servidores.

8.4 Salida de usuarios hacia Internet

La política USERS_TO_INTERNET habilita el acceso a Internet para los usuarios. El NAT está activo y utiliza la dirección de la interfaz de salida. Sobre esta regla se aplican los perfiles de Web Filter, Application Control y SSL/SSH Inspection que aparecen en la vista general de políticas.

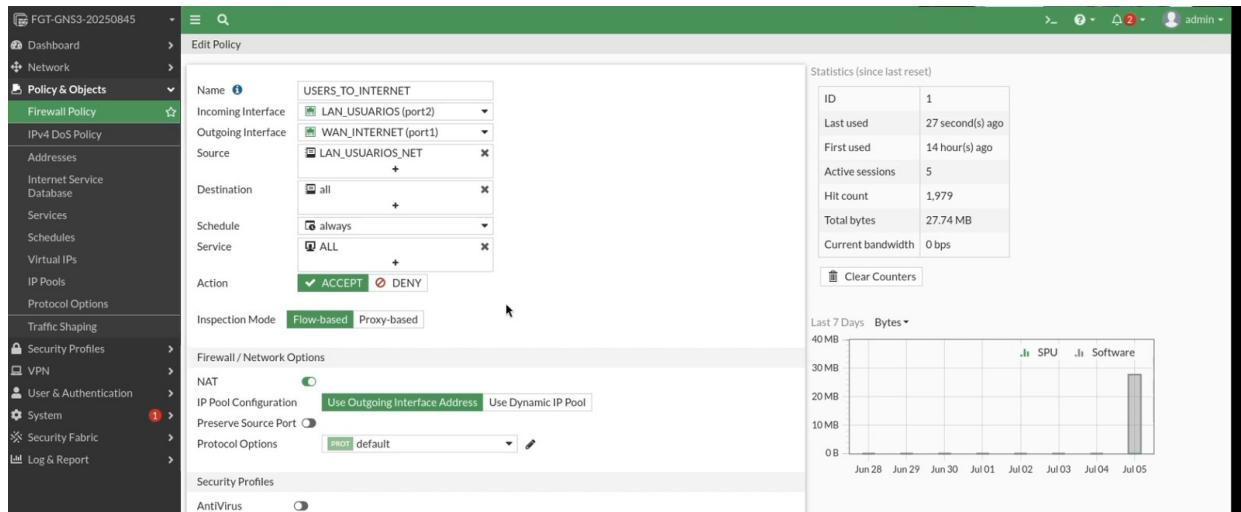


Figura 11. Política USERS_TO_INTERNET.

La política USERS_TO_INTERNET permite la salida desde LAN_USUARIOS hacia WAN_INTERNET. El origen es LAN_USUARIOS_NET, el destino all, servicio ALL, acción ACCEPT y NAT habilitado. En la lista general del firewall se evidencia que la política usa perfiles de seguridad para filtrado web, control de aplicaciones e inspección SSL/SSH.

9. Filtrado web, DNS Filter y bloqueo de WhatsApp

9.1 Bloqueo de redes sociales con Web Filter

El bloqueo de redes sociales se implementó mediante el perfil BLOCK_SOCIAL_NETWORKS. Este perfil documenta dos controles: bloqueo por categoría Social Networking y lista estática de URLs. La lista estática es especialmente importante porque el equipo muestra advertencia de licencia FortiGuard; por tanto, los dominios definidos manualmente permiten mantener evidencia local del control aplicado.

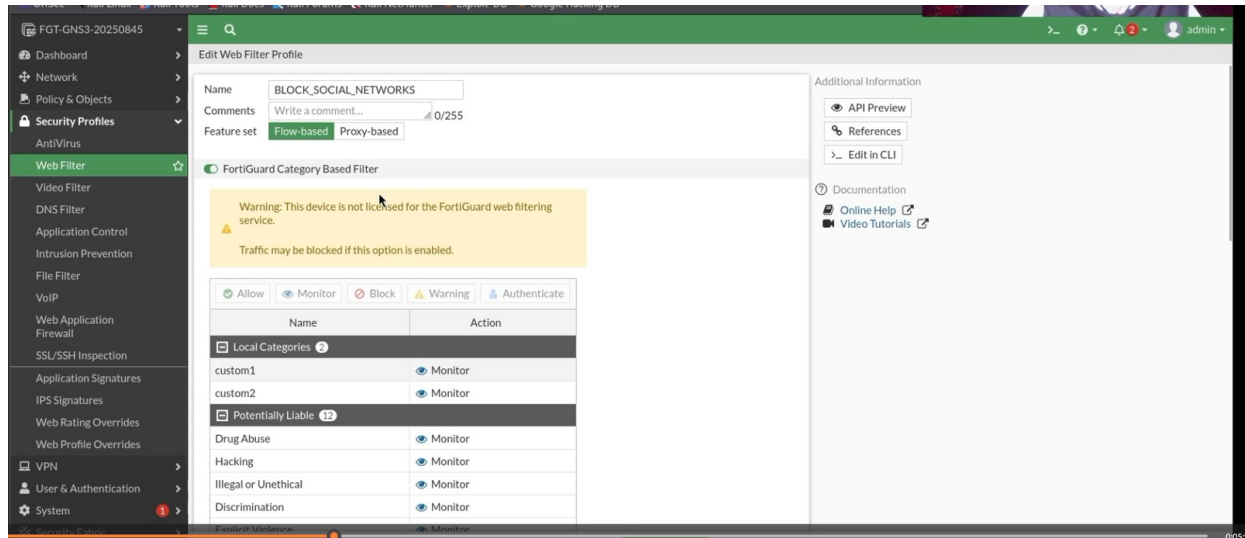


Figura 12. Perfil Web Filter BLOCK_SOCIAL_NETWORKS.

La evidencia muestra el perfil de Web Filter BLOCK_SOCIAL_NETWORKS. El filtro por categorías de FortiGuard está habilitado, aunque aparece una advertencia de licencia para el servicio de FortiGuard. Aun así, el perfil forma parte de la documentación de control web del laboratorio.

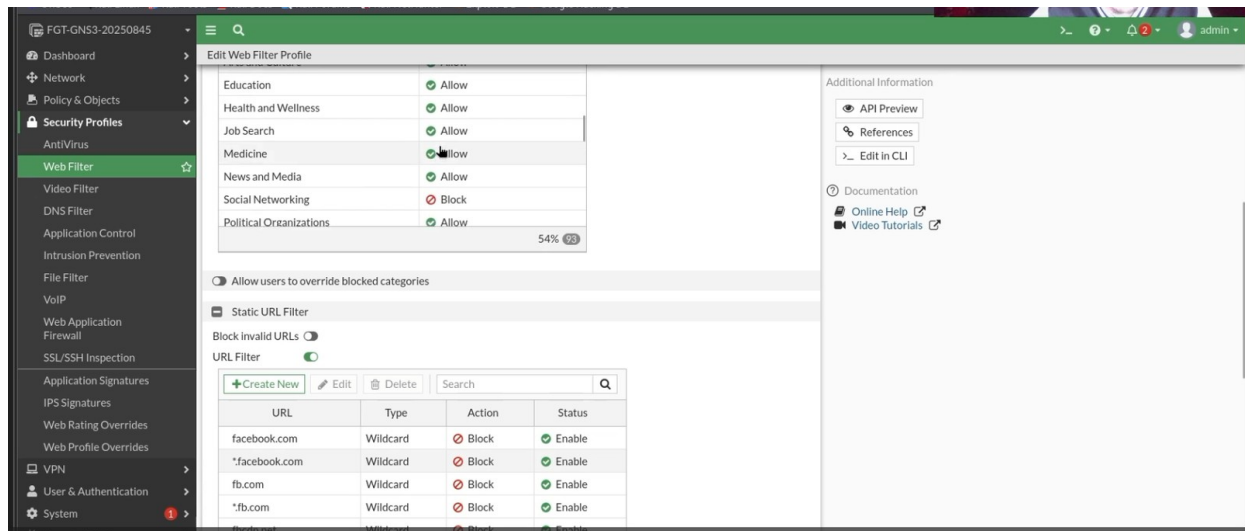


Figura 13. Bloqueo de categoría Social Networking.

En esta captura se observa que la categoría Social Networking está configurada con acción Block. También se observa el Static URL Filter habilitado, que complementa el bloqueo por categoría con dominios específicos.

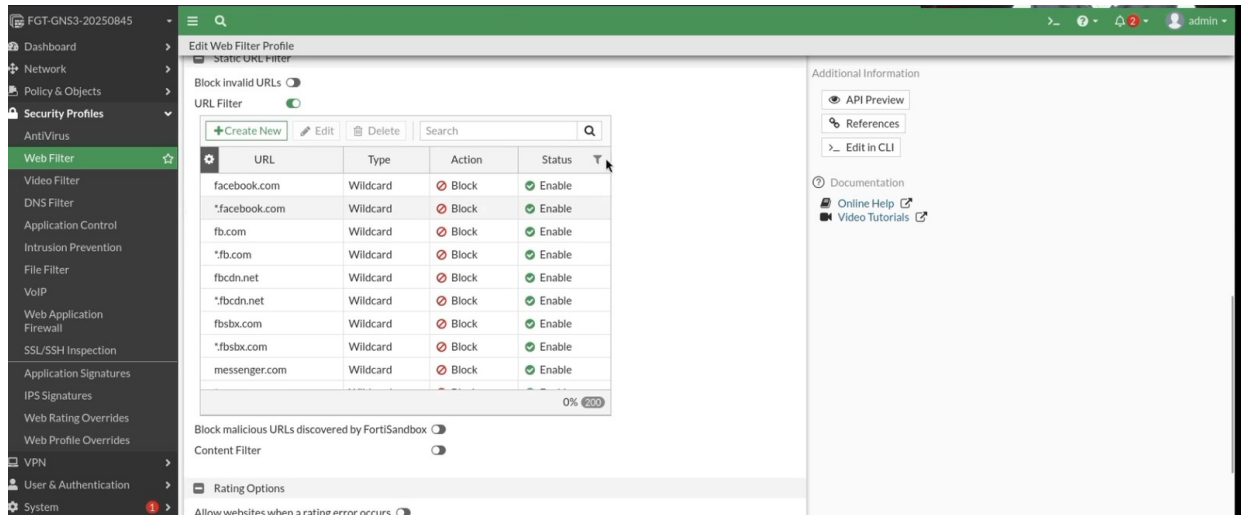


Figura 14. Filtro estático de URLs sociales.

La tabla de Static URL Filter contiene dominios y comodines como facebook.com, *.facebook.com, fb.com, *.fb.com, fbcdn.net, *.fbcdn.net, fbsbx.com y messenger.com con acción Block y estado Enable. Esta configuración refuerza el bloqueo de redes sociales aunque la categorización FortiGuard no esté licenciada.

9.2 Bloqueo de llamadas de WhatsApp con Application Control

Para WhatsApp se utilizó un perfil Application Control llamado BLOCK_WHATSAPP_CALLS. La evidencia muestra que el perfil existe y que se configuró un override sobre WhatsApp_VoIP.Call con acción Block. Esto ataca específicamente el requisito de bloquear llamadas por WhatsApp, no solamente el acceso al dominio web.

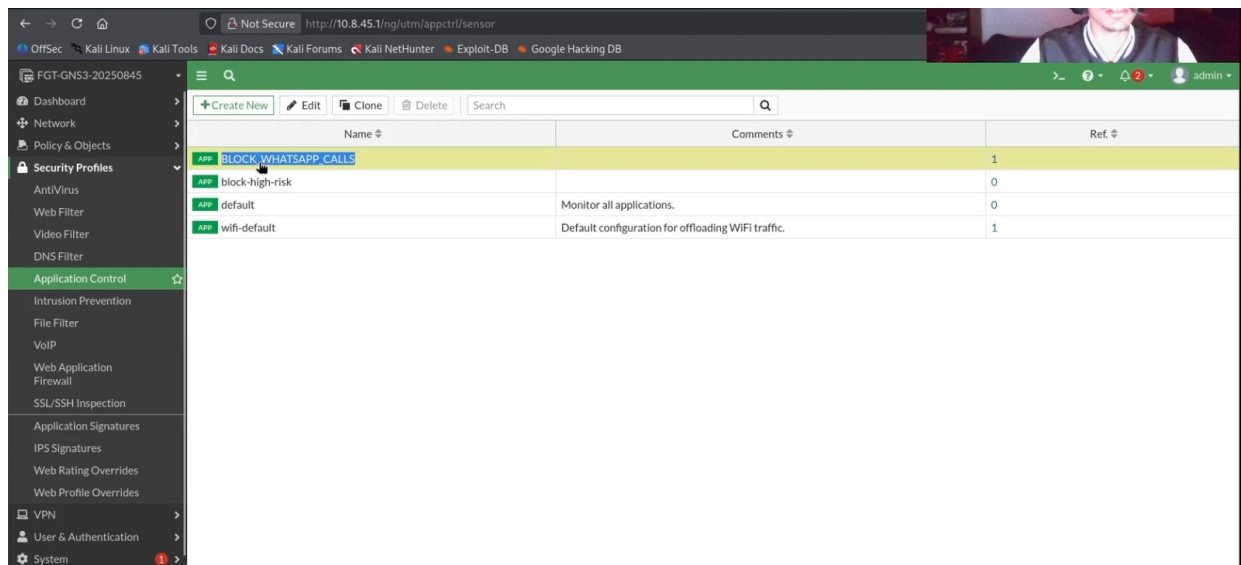


Figura 15. Perfil Application Control para WhatsApp.

La lista de Application Control muestra el perfil BLOCK_WHATSAPP_CALLS creado y referenciado por una política. Esto confirma que el perfil ya existe en el FortiGate y está disponible para ser aplicado al tráfico de usuarios hacia Internet.

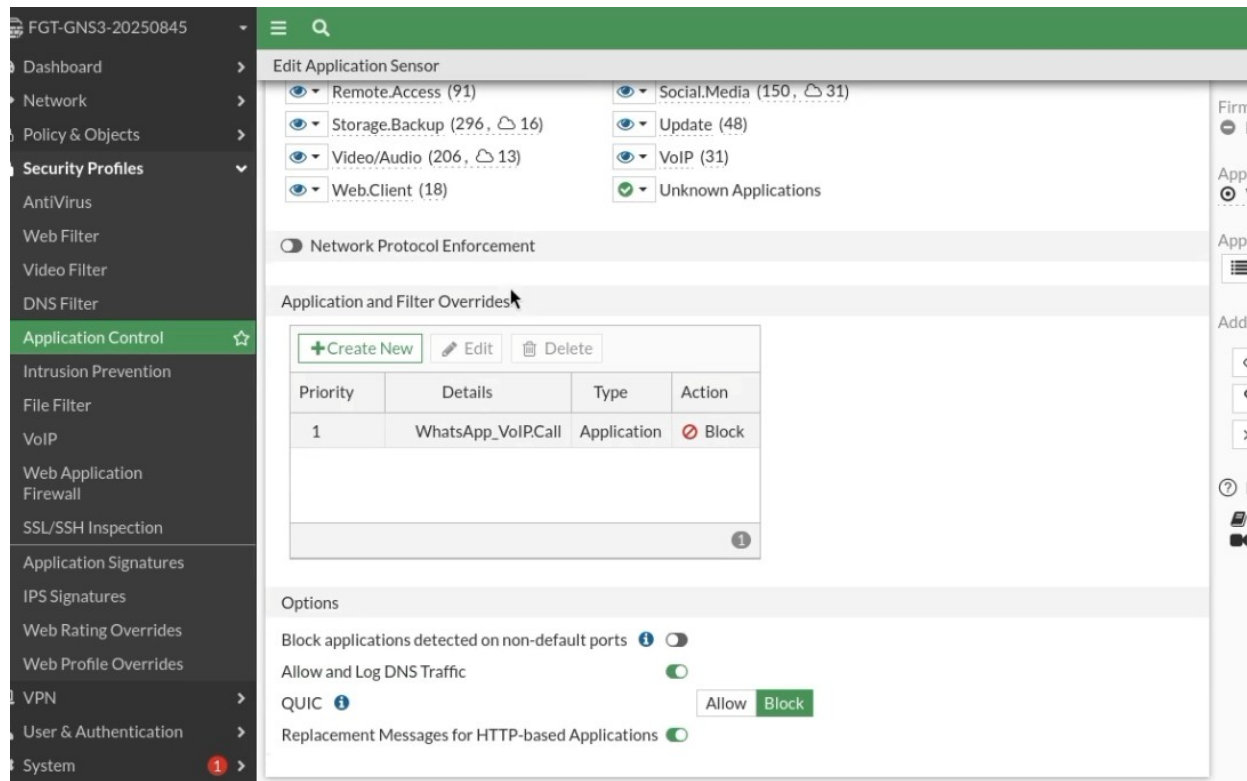


Figura 16. Bloqueo de WhatsApp VoIP Call.

La configuración del sensor de aplicaciones contiene una regla de override para WhatsApp_VoIP.Call con acción Block. También se observa QUIC configurado en Block, lo cual ayuda a evitar evasiones por transporte moderno usado por aplicaciones web y móviles. El perfil permite registrar tráfico DNS para apoyar la auditoría.

9.3 Bloqueo de itla.edu.do y subdominios

El bloqueo de itla.edu.do se realizó mediante DNS Filter, agregando el dominio raíz y el comodín *.itla.edu.do. La acción Redirect to Block Portal hace que el usuario sea redirigido al portal interno configurado para mostrar el mensaje de acceso bloqueado. Esta técnica permite demostrar claramente el bloqueo en el navegador.

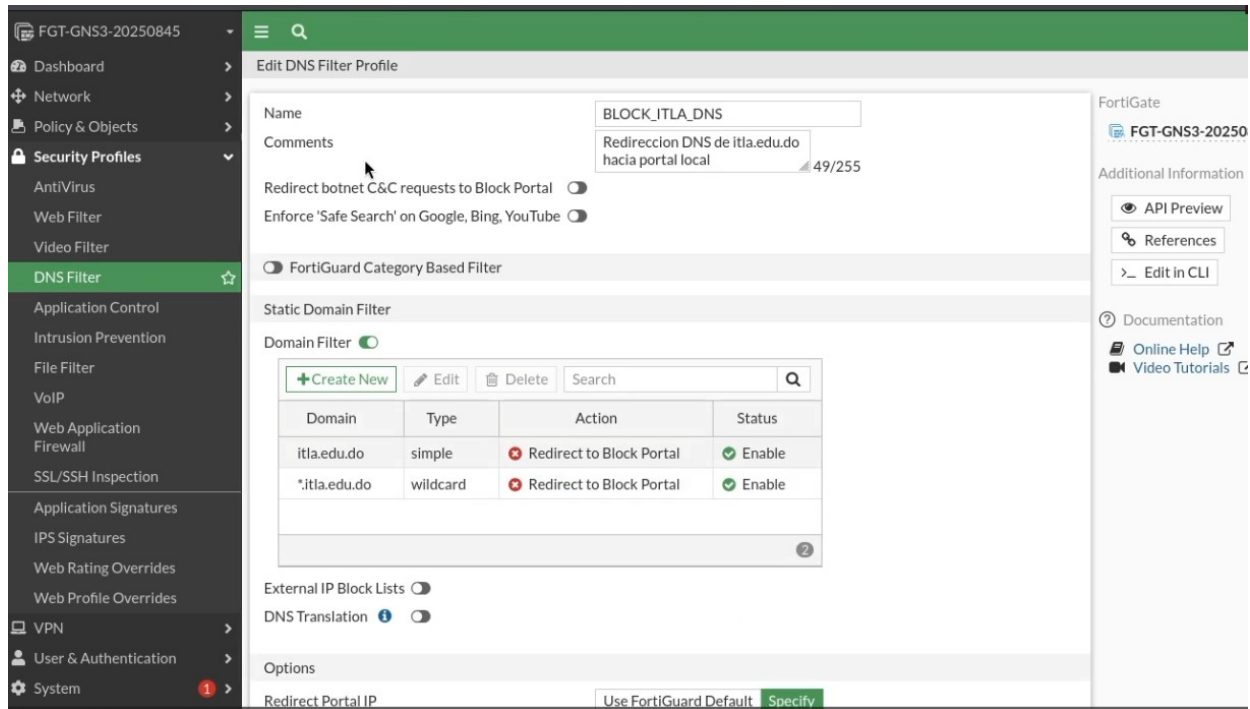


Figura 17. DNS Filter para itla.edu.do.

El perfil DNS Filter BLOCK_ITLA_DNS contiene reglas estáticas para itla.edu.do y *.itla.edu.do. La acción es Redirect to Block Portal y el estado está habilitado. Esto permite bloquear tanto el dominio raíz como subdominios del ITLA mediante resolución DNS controlada por FortiGate.

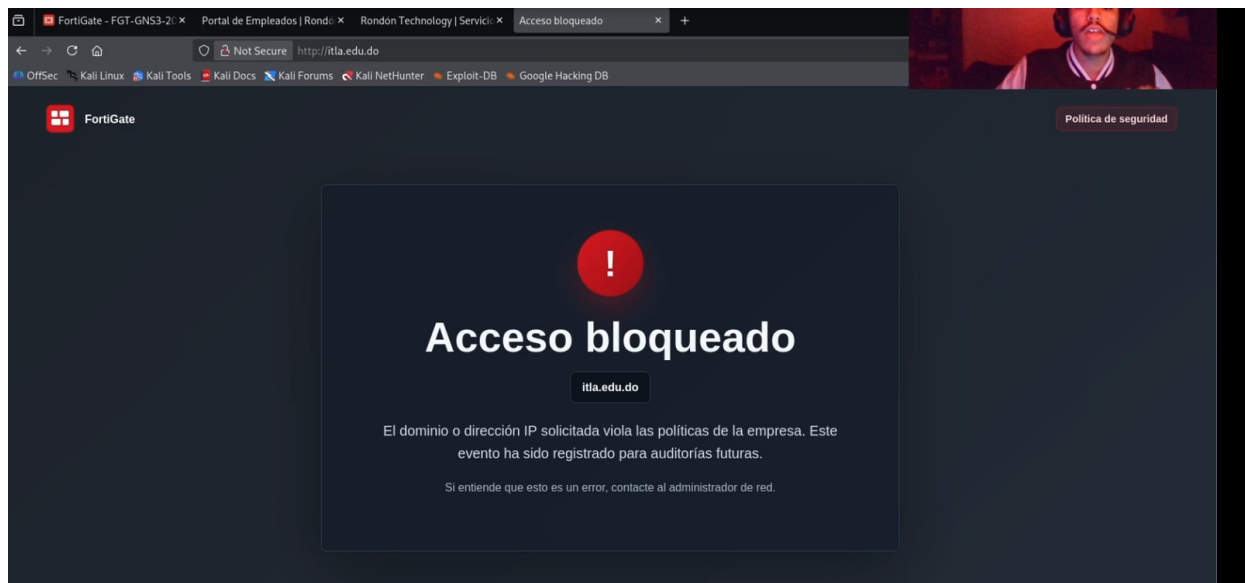
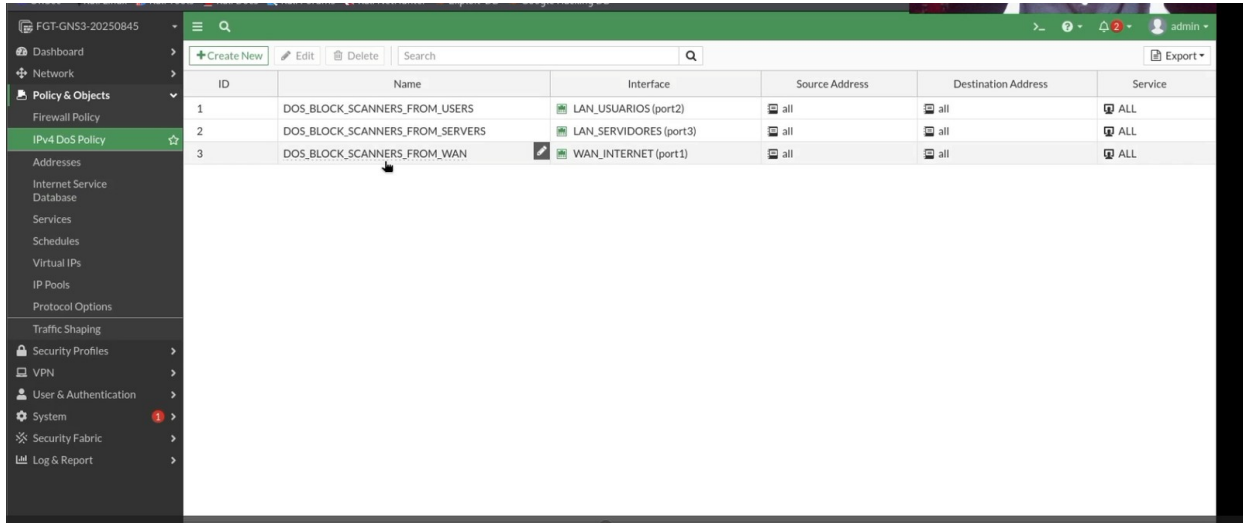


Figura 18. Portal interno de acceso bloqueado.

La evidencia del navegador muestra el acceso a http://itla.edu.do redirigido al portal interno de bloqueo. El portal indica Acceso bloqueado, muestra el dominio itla.edu.do y explica que el dominio o IP solicitada viola las políticas de la empresa. Esta prueba confirma la experiencia visible para el usuario final.

10. Detección y bloqueo de escáneres de red

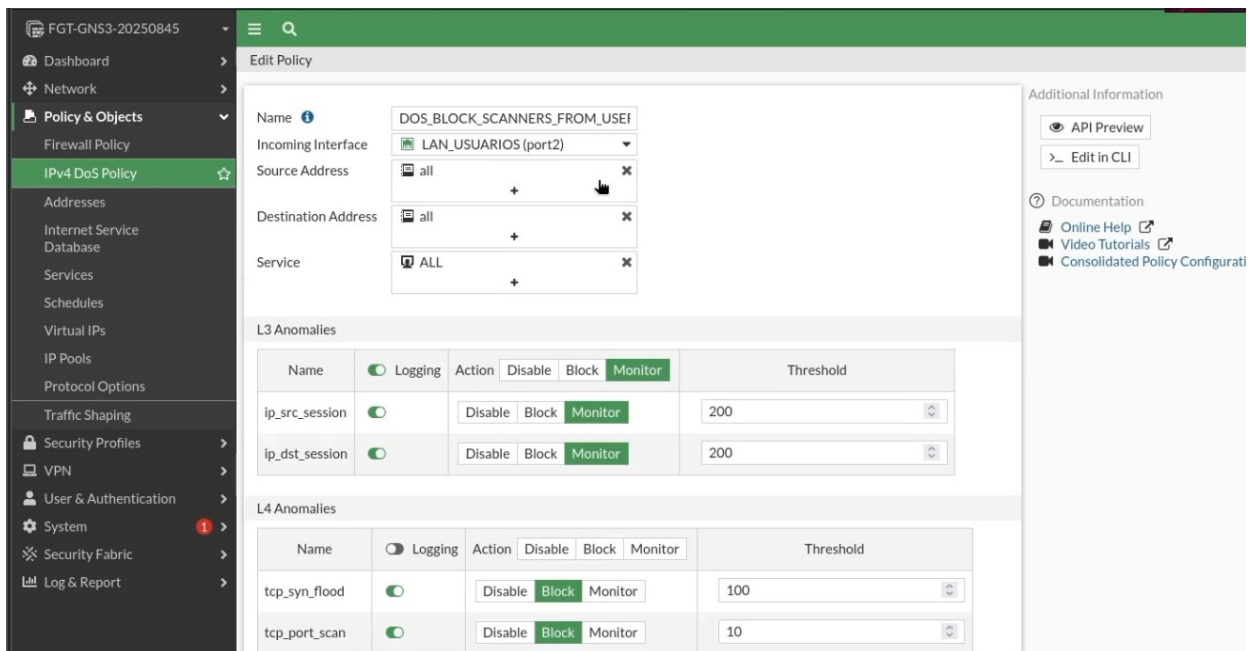
El laboratorio utiliza IPv4 DoS Policy para detectar comportamientos típicos de escaneo y abuso. Se configuraron políticas separadas para usuarios, servidores y WAN. En la política de usuarios se activaron anomalías L4 como tcp_port_scan, tcp_syn_flood, udp_scan e icmp_sweep. Los contadores y logs permiten evidenciar el origen del evento y la acción aplicada por el firewall.



ID	Name	Interface	Source Address	Destination Address	Service
1	DOS_BLOCK_SCANNERS_FROM_USERS	LAN_USUARIOS (port2)	all	all	ALL
2	DOS_BLOCK_SCANNERS_FROM_SERVERS	LAN_SERVIDORES (port3)	all	all	ALL
3	DOS_BLOCK_SCANNERS_FROM_WAN	WAN_INTERNET (port1)	all	all	ALL

Figura 19. Listado de políticas IPv4 DoS.

La pantalla IPv4 DoS Policy lista tres políticas: DOS_BLOCK_SCANNERS_FROM_USERS sobre LAN_USUARIOS, DOS_BLOCK_SCANNERS_FROM_SERVERS sobre LAN_SERVIDORES y DOS_BLOCK_SCANNERS_FROM_WAN sobre WAN_INTERNET. El objetivo es detectar y bloquear patrones de escaneo o abuso desde distintas zonas del firewall.



Name	Logging	Action	Threshold
L3 Anomalies			
ip_src_session	☒	Disable Block Monitor	200
ip_dst_session	☒	Disable Block Monitor	200
L4 Anomalies			
tcp_syn_flood	☒	Disable Block Monitor	100
tcp_port_scan	☒	Disable Block Monitor	10

Figura 20. DoS desde usuarios - anomalías L3 y primeras L4.

La política DOS_BLOCK_SCANNERS_FROM_USERS aplica sobre port2. El origen, destino y servicio están en all para evaluar todo el tráfico que entra desde usuarios. Se observan anomalías L3 ip_src_session e ip_dst_session en modo Monitor con umbral 200, y en L4 se habilitan controles como tcp_syn_flood y tcp_port_scan en Block.

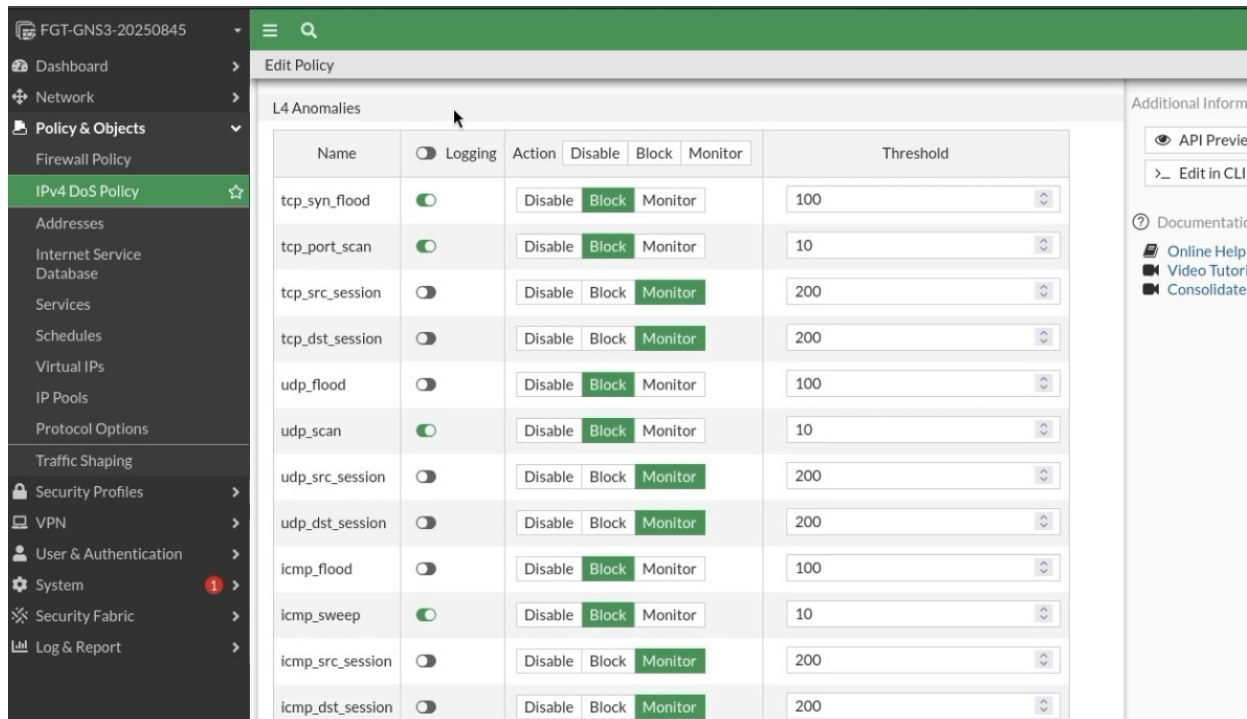


Figura 21. DoS desde usuarios - anomalías TCP, UDP e ICMP.

La segunda parte de la política muestra tcp_syn_flood, tcp_port_scan, udp_flood, udp_scan, icmp_flood e icmp_sweep con acción Block y umbrales definidos. Las opciones de logging están activas para eventos de escaneo clave, permitiendo detectar la fuente y el destino del comportamiento anómalo.

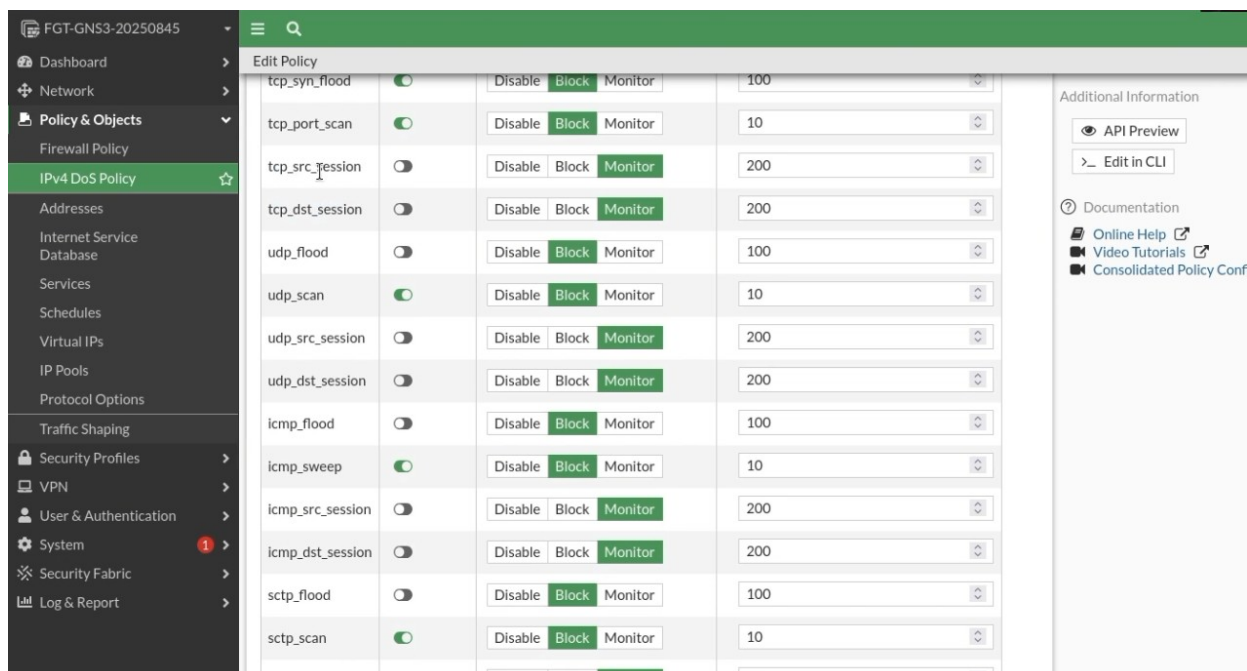


Figura 22. DoS desde usuarios - SCTP y sesiones.

La tercera parte continúa con controles L4, incluyendo sctp_flood y sctp_scan en Block. También se mantienen controles de sesión en Monitor para TCP, UDP, ICMP y SCTP. Esto amplía la detección más allá de TCP hacia otros protocolos.

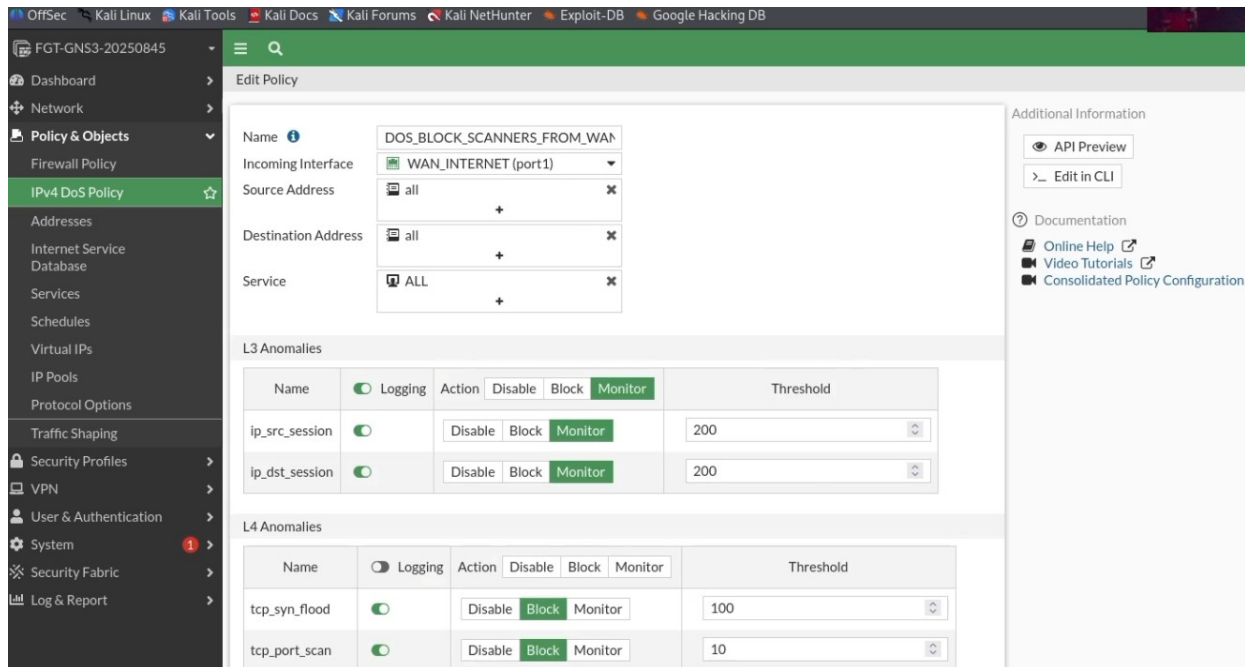


Figura 23. DoS desde WAN.

La política DOS_BLOCK_SCANNERS_FROM_WAN está aplicada a WAN_INTERNET, port1. En la parte visible se aprecian controles L3 en Monitor y controles L4 como tcp_syn_flood y tcp_port_scan en Block. Esta regla protege la entrada perimetral ante escaneos provenientes del exterior.

10.1 Pruebas de escaneo y lectura de logs

La prueba principal de escaneo se ejecutó desde Kali hacia el servidor web 10.8.45.130 usando Nmap. Como el FortiGate se encuentra entre usuarios y servidores, el escaneo atraviesa las políticas de control. Los puertos no permitidos son denegados por DENY_USERS_TO_SERVERS y el comportamiento de escaneo se registra también como anomalía.

```
sudo nmap -sS -Pn -p 1-1000 10.8.45.130
```

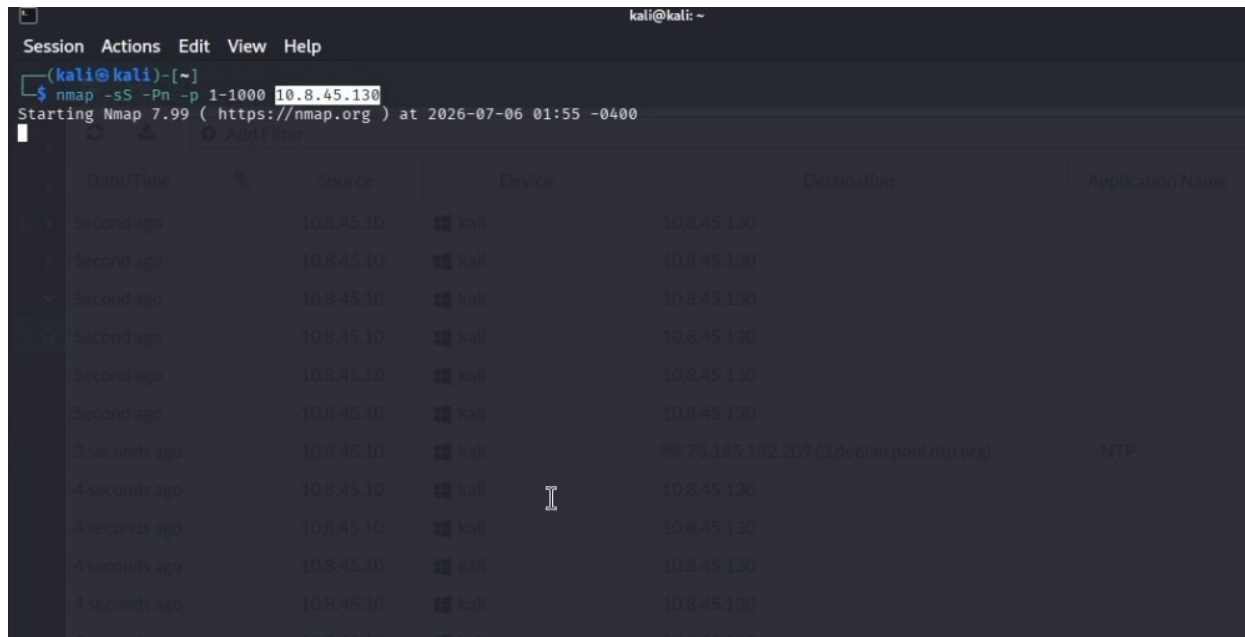


Figura 24. Escaneo Nmap contra el servidor web.

La terminal Kali ejecuta un escaneo SYN con `nmap -sS -Pn -p 1-1000` hacia 10.8.45.130, que corresponde al servidor web. Esta prueba genera múltiples intentos de conexión contra puertos del servidor y sirve para evidenciar tanto el bloqueo por política como la detección de comportamiento anómalo.

Date/Time	Source	Device	Destination	Application Name	Result	Policy ID
5 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
5 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
3 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
3 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
3 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
3 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
3 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
3 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
3 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)

Figura 25. Logs de Forward Traffic por violación de política.

Los logs de Forward Traffic muestran múltiples eventos desde 10.8.45.10 hacia 10.8.45.130 con resultado `Deny: policy violation` y Policy ID `DENY_USERS_TO_SERVERS`. Esto evidencia que el escaneo intentó acceder a servicios no permitidos y fue detenido por la regla de denegación hacia servidores.

También se ejecutó una prueba dirigida al gateway 10.8.45.1. Esta prueba se interpreta de forma distinta, porque 10.8.45.1 es la propia interfaz del FortiGate. Por eso, su valor principal es generar o validar eventos de anomalía sobre el firewall, no demostrar el control entre usuarios y servidores.

Date/Time	Source	Device	Destination	Application Name	Result	Policy ID
6 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)

Figura 26. Escaneo Nmap al gateway.

La terminal muestra un escaneo hacia 10.8.45.1, que es el gateway de usuarios y la interfaz port2 del FortiGate. Esta prueba no valida el control entre usuarios y servidores, sino el comportamiento del propio firewall ante intentos de escaneo dirigidos a su interfaz.

```

(kali@kali)-[~]
$ nmap -sS -Pn -p 1-1000 10.8.45.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 01:57 -0400
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.05% done; ETC: 01:59 (0:01:53 remaining)

```

Figura 27. Logs de anomalías por escaneo.

La sección Log & Report > Anomaly muestra eventos de severidad alta con acciones clear_session y nombres de ataque tcp_syn_flood, tcp_port_scan, udp_scan y udp_flood. Se observan fuentes como 10.8.45.10 y 10.8.45.130. Esta evidencia confirma que FortiGate detectó patrones de escaneo y anomalía.

11. Servidor web y validación de acceso HTTP

El servidor Windows con IIS aloja sitios de prueba bajo el dominio rondontech.test. Estos sitios permiten validar que el DNS interno resuelve correctamente, que la política de acceso web permite tráfico legítimo y que el WAF no bloquea solicitudes normales.

Date/Time	Severity	Source	Protocol	User	Action	Count	Attack Name
28 seconds ago	High	10.8.45.10	6		clear_session	1	tcp_syn_flood
28 seconds ago	High	10.8.45.10	6		clear_session	213	tcp_port_scan
5 minutes ago	High	10.8.45.10	6		clear_session	402	tcp_port_scan
7 minutes ago	High	10.8.45.10	6		clear_session	429	tcp_port_scan
10 minutes ago	High	10.8.45.130	17		clear_session	2	udp_scan
20 minutes ago	High	10.8.45.130	6		clear_session	69	tcp_port_scan
21 minutes ago	High	10.8.45.130	6		clear_session	337	tcp_port_scan
22 minutes ago	High	142.251.154.119	17		clear_session	11	udp_flood
22 minutes ago	High	10.8.45.130	6		clear_session	182	tcp_port_scan
22 minutes ago	High	23.34.82.10	17		clear_session	675	udp_flood
23 minutes ago	High	23.62.61.208	17		clear_session	1	udp_flood
23 minutes ago	High	10.8.45.130	6		clear_session	334	tcp_port_scan
57 minutes ago	High	10.8.45.130	17		clear_session	4	udp_scan
Hour ago	High	10.8.45.130	17		clear_session	1	udp_scan
Hour ago	High	10.8.45.10	6		clear_session	1	tcp_port_scan

Figura 28. Portal de empleados en servidor web.

El navegador muestra empleados.rondontech.test con una página interna de Rondón Technology. Se visualiza una sesión activa y tarjetas de supervisión, auditoría y equipo. Esta evidencia confirma que el servidor IIS responde a un sitio interno publicado dentro de la LAN de servidores.

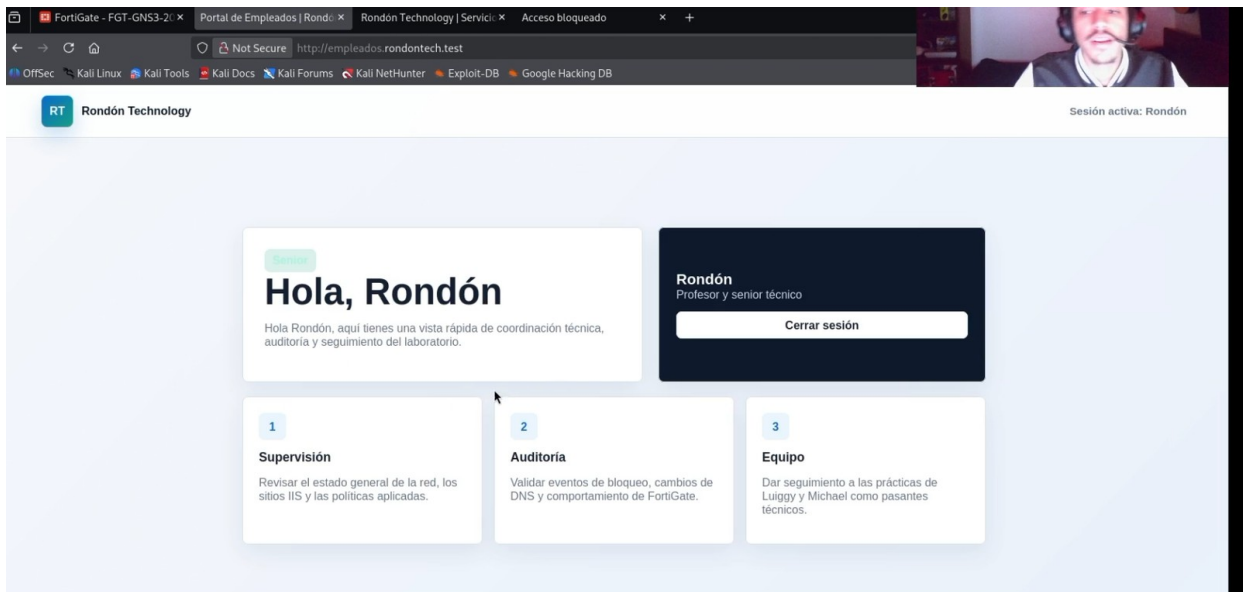


Figura 29. Sitio público www.rondontech.test.

La página www.rondontech.test muestra el sitio principal de Rondón Technology con contenido corporativo sobre infraestructura, redes empresariales y ciberseguridad. Esta prueba valida que el tráfico web permitido llega correctamente al servidor web.

12. Web Application Firewall

El perfil WAF_WEB_SERVER_PROTECTION protege el servidor web desde la política de acceso de usuarios hacia servidores. Las firmas activas bloquean categorías comunes de ataques web, como XSS, SQL Injection, Generic Attacks, Trojans y Known Exploits. Además, las constraints limitan solicitudes HTTP malformadas o con parámetros excesivos.

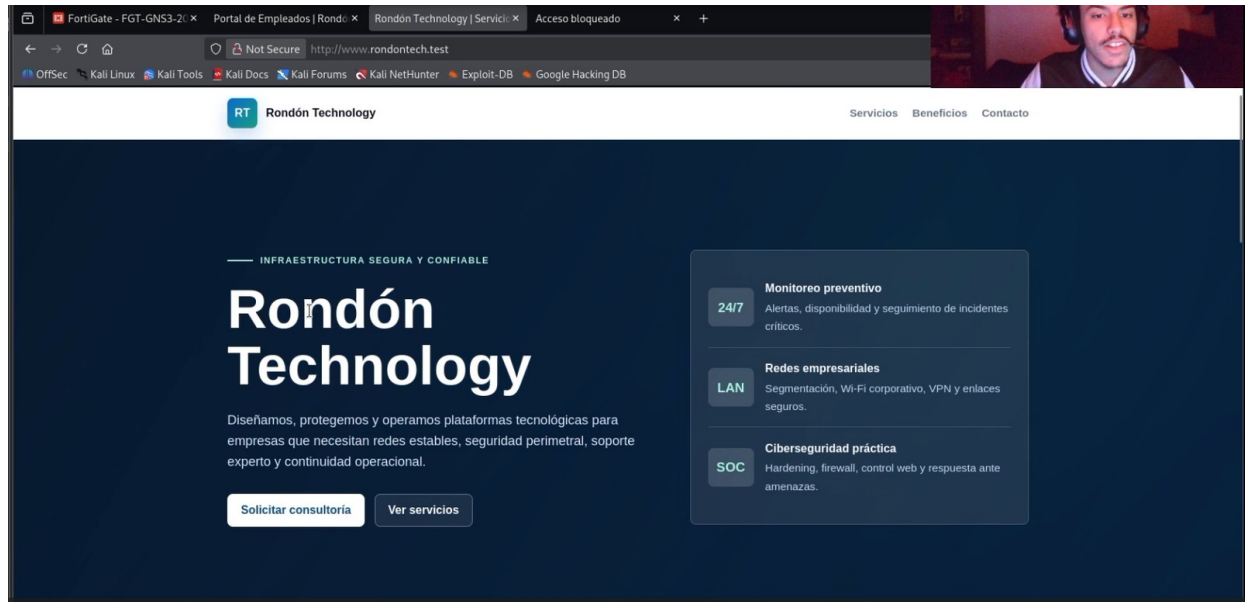


Figura 30. Perfil WAF y firmas principales.

La configuración WAF_WEB_SERVER_PROTECTION contiene firmas habilitadas para Cross Site Scripting, SQL Injection, Generic Attacks, Trojans y Known Exploits con acción Block. Information Disclosure aparece en Allow y Bad Robot en Monitor. Esto muestra la defensa de capa de aplicación aplicada al servidor web.

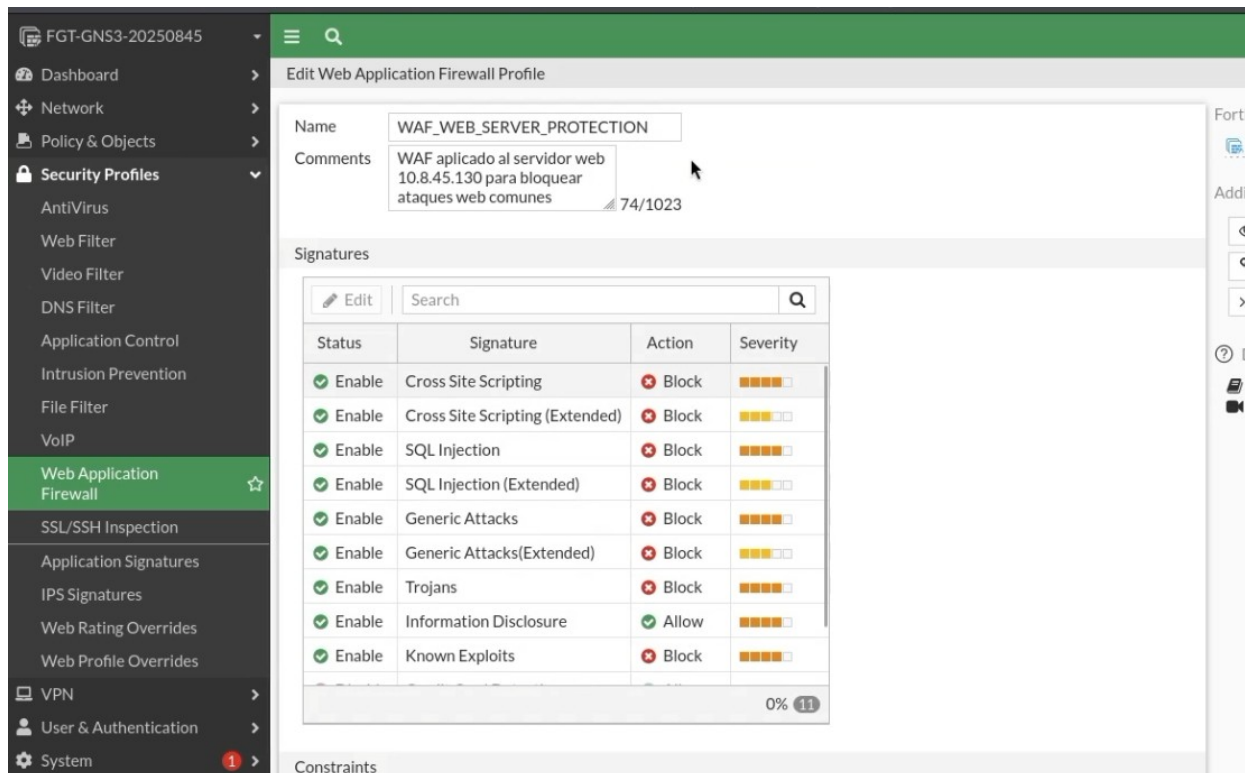


Figura 31. WAF, Bad Robot y primeras constraints.

La segunda captura del WAF confirma el final de la lista de firmas, incluyendo Bad Robot en Monitor y Credit Card Detection deshabilitado. En constraints aparecen Illegal HTTP Version e

Illegal HTTP Request Method con acción Block, lo que permite filtrar solicitudes HTTP malformadas o no permitidas.

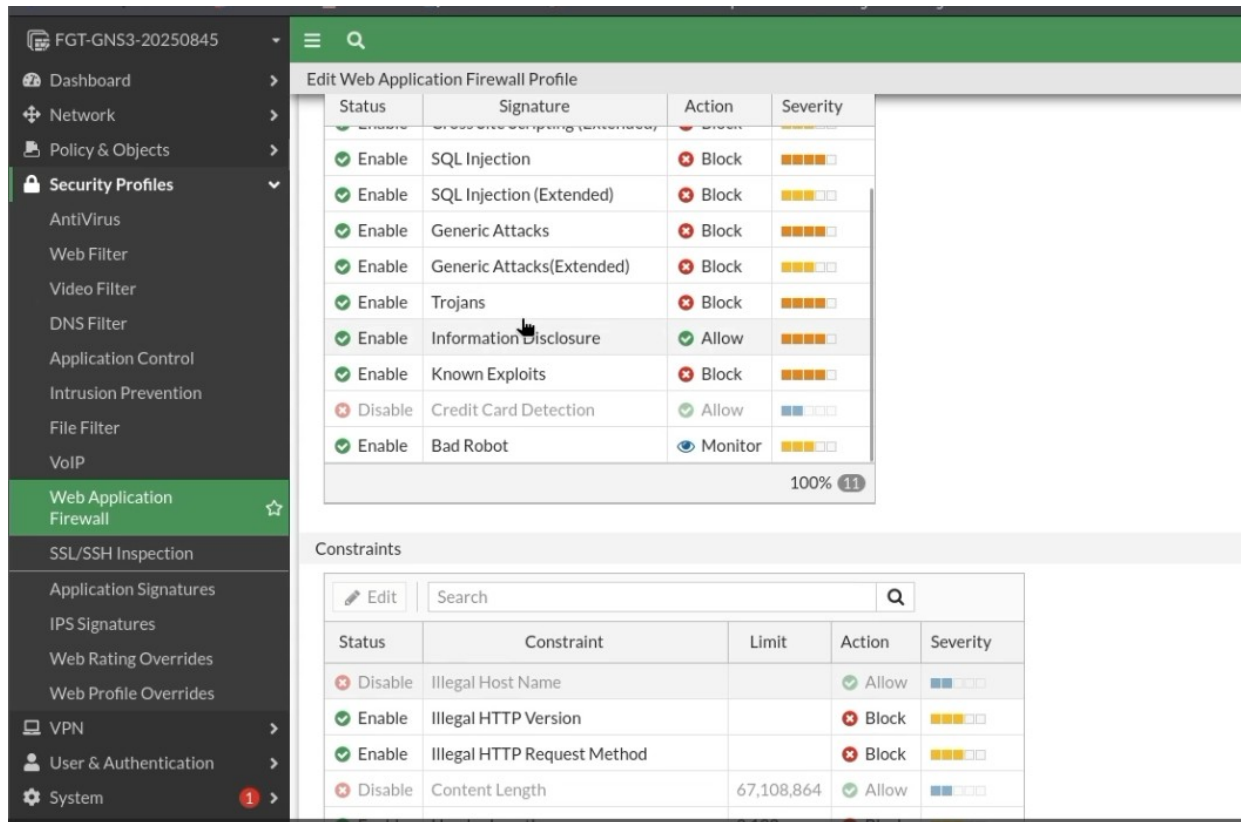


Figura 32. WAF constraints HTTP.

La sección Constraints del WAF muestra controles sobre Header Length, Header Line Length, Number of Header Lines in Request, Total URL and Body Parameters Length, Total URL Parameters Length, Number of URL Parameters, Number of Cookies in Request, Number of Ranges in Range Header y Malformed Request. La mayoría aparece en Block, reforzando la validación de solicitudes HTTP.

12.1 Prueba de tráfico legítimo y ataque XSS

La primera prueba realiza una solicitud normal hacia www.rondontech.test y recibe HTTP 200. Esto confirma que el WAF está inspeccionando sin romper el servicio legítimo. La segunda prueba intenta insertar una carga XSS en el parámetro q; FortiGate responde con una página de Web Application Firewall y registra el evento como firma bloqueada.

```
curl -s -o /dev/null -w "Pagina normal: %{http_code}\n" http://www.rondontech.test/
curl -i "http://www.rondontech.test/?q=%3Cscript%3Ealert%281%29%3C%2Fscript%3E"
```

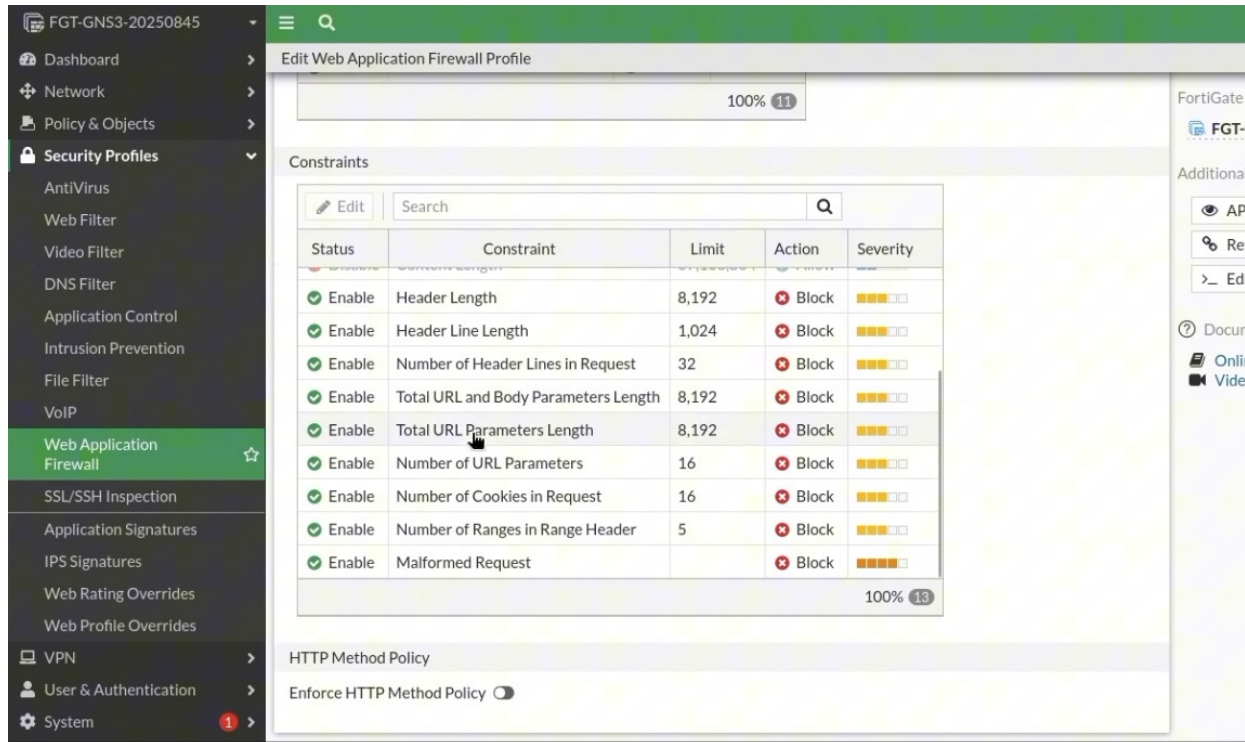


Figura 33. Prueba HTTP normal permitida.

La terminal Kali ejecuta curl contra <http://www.rondontech.test> y recibe Página normal: 200. Esto demuestra que el WAF no rompe el tráfico legítimo: la página normal carga correctamente mientras las firmas protegen contra patrones maliciosos.

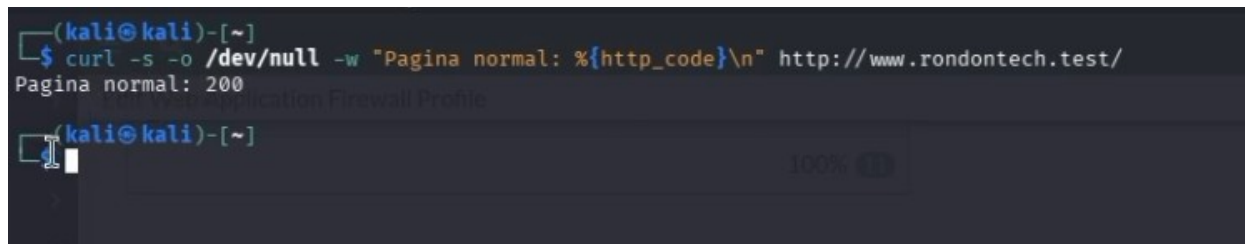


Figura 34. Bloqueo de XSS por WAF.

La última evidencia muestra el intento de acceder a www.rondontech.test con un parámetro que contiene una carga XSS codificada. FortiGate responde con una página de Web Application Firewall indicando que la transferencia fue bloqueada, con Event ID 10000057 y Event Type signature. Esto confirma la protección de aplicación ante XSS.

13. Pruebas de validación

Las siguientes pruebas resumen la validación operativa desde Kali Linux. El objetivo es comprobar conectividad, resolución DNS, redirección de dominios bloqueados, acceso web legítimo, bloqueo WAF y eventos de escaneo.

```
ip -br a
ip route
cat /etc/resolv.conf
ping -c 2 10.8.45.1
```

```
ping -c 2 8.8.8.8
nslookup google.com 10.8.45.1
nslookup www.rondontech.test 10.8.45.1
nslookup facebook.com 10.8.45.1
nslookup whatsapp.com 10.8.45.1
nslookup itla.edu.do 10.8.45.1
curl -4 -s -o /dev/null -w "Pagina normal: %{http_code}\n" http://www.rondontech.test/
sudo nmap -sS -Pn -p 1-1000 10.8.45.130
```

14. Observaciones técnicas

Durante el laboratorio se identificó que algunas opciones CLI de DNS Database varían según versión de FortiOS. En particular, el valor set type master y el hostname comodín * pueden generar errores en algunas versiones. Por eso, las configuraciones finales de DNS se validaron por GUI y mediante nslookup desde Kali.

También se observó que el bloqueo de redes sociales puede implementarse con varias capas: Web Filter, DNS Filter, DNS Database y Application Control. En entornos con licencia FortiGuard activa, la categorización por reputación y categoría ofrece mayor cobertura. En este laboratorio, las listas estáticas y redirecciones internas permitieron demostrar el comportamiento sin depender completamente de FortiGuard.

Para el requisito de solo HTTP hacia el servidor, la política debe quedar con servicio HTTP si la rúbrica lo exige de forma estricta. En algunas capturas se observa HTTPS agregado para pruebas de portal y certificado; esto no cambia el principio de segmentación, pero debe ajustarse si se presenta como control de mínimo privilegio absoluto.

15. Conclusión

El laboratorio cumple el objetivo de implementar políticas corporativas sobre FortiGate Firewall. Se configuraron interfaces, direccionamiento, DHCP, ruta por defecto, NAT, políticas de firewall, filtros de contenido, Application Control, DNS Filter, políticas DoS y WAF. Las evidencias muestran tanto la configuración como el resultado funcional: navegación permitida, dominios bloqueados, tráfico no autorizado denegado, escaneos registrados y ataques web detenidos.

La implementación demuestra que FortiGate puede actuar como firewall perimetral, servidor de servicios básicos de red, punto de inspección de aplicaciones y capa de defensa web dentro de una red segmentada. La combinación de reglas explícitas, perfiles de seguridad y logs proporciona una base sólida para auditoría y defensa en ambientes corporativos.

16. Anexos

16.1 Enlaces del entregable

Repositorio GitHub: <https://github.com/iClexi/Fortigate-Corporate-Policies>

Video demostrativo: <https://youtu.be/9Mjof5YxtKg?si=TpSuH9TQf1OwJGXo>

16.2 Script base compatible del FortiGate

El repositorio incluye el archivo `scripts/fortigate_base_config_compatible.cli`. Este script reconstruye la configuración base del laboratorio y evita comandos que generaron errores en la versión utilizada durante la práctica.

Archivos incluidos en el repositorio
`scripts/fortigate_base_config_compatible.cli`
`scripts/kali_verification.sh`
`scripts/gui_security_profiles_notes.md`